

Authentication Strategy

Agri-Sync uses **Laravel Sanctum** to handle two simple authentication scenarios:

- 1. **Web Admin:** Cookie/Session based login for a secure dashboard experience.
- 2. **Mobile PWA:** Bearer Token logic for persistent, offline-capable field entry.

1. Dashboard Login (Cookies)

The Admin Dashboard uses standard session-based auth.

- **Login:** Technicians or Admins log in via `POST /api/v1/auth/login`.
- **Pre-check:** We only allow users where `is_active` is true.
- **Session:** Laravel manages the session cookie and CSRF protection automatically.
- **Roles:** Access is managed by checking the `user_roles` table for `admin` or `manager` roles.

2. PWA Login (Tokens)

For the mobile app, we use Personal Access Tokens so the user stays logged in even if they lose connection.

- **Login:** Mobile users log in via `POST /api/v1/auth/token`.
- **Token:** The API returns a secret token.
- **Storage:** The PWA stores this token in **IndexedDB**.
- **Auth:** Every request to the server includes: `Authorization: Bearer <token>`.
- **Expiration:** Tokens are valid for 6 months to avoid constant logins in the field.

3. Roles & Permissions

Directly linked to the `app_role` enum and the `user_roles` table:

Role	Interface	Permissions
technician	Mobile	Create irrigation/fertilizer logs.
manager	Admin	View reports and plots (Read-only).
admin	Both	Manage everything (Users, Plots, Settings).

Administrators can configure and update specific permissions and feature access dynamically through the management panel.

4. Security Basics

- All traffic must use **HTTPS**.
- Passwords are hashed in the `password_hash` column.
- Admins can delete tokens or deactivate users at any time to cut off access.